

Password Management Policy

Policy No: POL-IT-005 | Version: v1.8 | Department: IT Security | Effective: March 17, 2026

1. PURPOSE

This policy defines requirements for creating, maintaining, and protecting passwords used to access company information systems. Strong password practices are a critical first line of defense against unauthorized access.

2. SCOPE

This policy applies to all employees, contractors, and third-party users who have credentials for any company system, application, database, or network resource.

3. TABLE OF CONTENTS

Section	Title
4	Password Creation Standards
5	Password Management
6	Multi-Factor Authentication
7	System & Service Accounts
8	Password Storage & Sharing
9	Breach Procedures

4. PASSWORD CREATION STANDARDS

4.1 Minimum Requirements

All passwords for company systems must meet the following minimum requirements:

- Minimum length: 12 characters (16+ recommended for privileged accounts).
- Must contain at least one uppercase letter (A-Z).
- Must contain at least one lowercase letter (a-z).
- Must contain at least one number (0-9).
- Must contain at least one special character (!@#\$%^&*...).
- Must not contain the user's name, username, or company name.
- Must not be based on easily guessable information (birthdays, addresses, etc.).

4.2 Password Strength Examples

- Weak (NOT acceptable): password123, Company2024, JohnSmith01.
- Strong (acceptable): T\$9kLm@2024!xR, W#8jPqN*7vRd!2Ks.

Note: Use a passphrase approach for memorable strong passwords: 'Coffee@7am!IsGreat' — long, complex, and memorable.

5. PASSWORD MANAGEMENT

5.1 Password Change Requirements

- Standard user passwords: Must be changed every 90 days.
- Privileged/admin account passwords: Must be changed every 30 days.
- Passwords must be changed immediately upon any suspected compromise.
- New passwords must differ from the last 10 previously used passwords.

5.2 Default Passwords

Default passwords on all new accounts and devices must be changed before first use. Default vendor/manufacture passwords on devices must be changed during initial setup.

5.3 Account Lockout

- Accounts are locked after 5 consecutive failed login attempts.
- Locked accounts must be unlocked by the IT Helpdesk after identity verification.
- Repeated lockouts must be investigated as a potential security incident.

6. MULTI-FACTOR AUTHENTICATION

MFA provides an additional layer of security beyond passwords. MFA is mandatory for:

- All remote access via VPN or remote desktop.
- Access to cloud services (Microsoft 365, AWS, Google Workspace).
- Administrative and privileged accounts.
- Access to financial and HR systems.
- Any system containing Confidential or Restricted data.

Approved MFA methods: Authenticator app (Microsoft/Google Authenticator), hardware tokens (YubiKey), or SMS OTP. SMS OTP is the least preferred method due to SIM-swap risks.

7. SYSTEM & SERVICE ACCOUNTS

- Service accounts must use auto-generated complex passwords (minimum 24 characters).
- Service account passwords must be stored in the company-approved Privileged Access Management (PAM) vault.
- Service account credentials must never be hardcoded in scripts or source code.
- All service accounts must be reviewed quarterly by the IT Security team.

- Unused service accounts must be disabled and reviewed for decommissioning.

8. PASSWORD STORAGE & SHARING

8.1 Password Managers

Employees must use the company-approved password manager (LastPass Enterprise / 1Password Business) to store and manage passwords. Storing passwords in browsers, plain text files, sticky notes, or spreadsheets is strictly prohibited.

8.2 Password Sharing

- Passwords must NEVER be shared with anyone, including IT staff, managers, or colleagues.
- If access delegation is required, use proper role-based access controls (RBAC).
- IT staff will never ask for your password via email, chat, or phone.

Note: If you suspect your password has been compromised, change it immediately and notify IT Security.

9. BREACH PROCEDURES

If a password breach is suspected or confirmed:

- Immediately change the compromised password from a secure, unaffected device.
- Notify IT Security at security@company.com within 30 minutes.
- Review recent account activity for unauthorized actions.
- Enable or verify MFA on the affected account.
- Do not reuse the compromised password or any similar variations.

ACKNOWLEDGEMENT

EMPLOYEE ACKNOWLEDGEMENT

I, the undersigned, confirm that I have read, understood, and agree to comply with this policy. I understand that violation of this policy may result in disciplinary action.

Employee Name:	_____	Date:	_____
Employee ID:	_____	Signature:	_____
Department :	_____	Manager:	_____

For questions regarding this policy, contact the IT Department at it-policy@company.com